

Encuesta integral sobre adopción de SSVC y gestión de vulnerabilidades

Versión 1.0 – Diseñada para responsables de ciberseguridad, riesgo, TI, cumplimiento y continuidad de negocio.

Objetivo: comprender hasta qué punto el marco SSVC y los enfoques de priorización basada en riesgo están realmente vivos (o solo anunciados) en su organización. [web:19][web:30][web:8]

0. Identificación de la organización (opcional)

0.1. Tipo de organización principal

- ☐ Operador de servicios esenciales (NIS/NIS2)
- ☐ Administración pública (central, autonómica, local)
- ☐ Empresa privada no regulada como esencial
- ☐ Proveedor de servicios gestionados / MSSP
- ☐ Otro (especifique): ____

0.2. Sector principal de actividad

- ☐ Energía
- ☐ Agua
- ☐ Transporte
- ☐ Salud
- ☐ Finanzas
- ☐ TIC / Cloud / Data center
- ☐ Industria / OT
- ☐ Otro (especifique): ____

0.3. Tamaño aproximado de la organización (empleados)

- ☐ < 250
- ☐ 250–1 000
- ☐ 1 001–5 000
- ☐ 5 001–20 000
- ☐ > 20 000

0.4. Ámbito geográfico principal

- ☐ España exclusivamente
- ☐ España + UE
- ☐ Global

1. Gobernanza de la gestión de vulnerabilidades

1.1. ¿Existe una política formal de gestión de vulnerabilidades aprobada por la alta dirección? [web:33][web:39]

- ☐ Sí, formalmente aprobada y revisada al menos anualmente
- ☐ Sí, pero desactualizada o sin revisión formal

- ☐ Existe solo como práctica de hecho, no como política formal
- ☐ No existe

1.2. ¿Quién es el máximo responsable de la priorización de vulnerabilidades?

- ☐ CISO o equivalente
- ☐ Director de TI / Infraestructuras
- ☐ Responsable de Riesgos / Compliance
- ☐ Equipo SOC / CERT interno
- ☐ No está claramente definido

1.3. ¿Con qué frecuencia se informa al Consejo / Alta Dirección sobre el estado de vulnerabilidades críticas y medidas asociadas? [web:33][web:36][web:39]

- ☐ Mensualmente o más frecuente
- ☐ Trimestralmente
- ☐ Anualmente
- ☐ Solo en caso de incidentes graves
- ☐ Nunca / No aplica

1.4. ¿Cómo describiría la integración de la gestión de vulnerabilidades en el sistema general de gestión de riesgos de la organización? [web:33]

- ☐ Totalmente integrada (mismo ciclo, mismas matrices de riesgo, misma supervisión)
- ☐ Parcialmente integrada (algunos reportes y métricas comunes)
- ☐ Tratada como disciplina separada, pero coordinada ad hoc
- ☐ Aislada en equipos técnicos, sin conexión real con la gestión de riesgos corporativos

1.5. ¿La Junta o Alta Dirección ha recibido formación específica sobre gestión de vulnerabilidades, CVE/KEV, SSVC o EPSS en los últimos 24 meses? [web:39]

- ☐ Sí, formación estructurada y documentada
- ☐ Formación informal (charlas internas, sesiones ad hoc)
- ☐ No, pero está planificada
- ☐ No, ni se la espera

2. Descubrimiento, inventario y contexto de activos

2.1. ¿La organización dispone de un inventario actualizado de activos (IT, OT, cloud, terceros) vinculable a CPE/CVE? [web:33][web:35]

- ☐ Sí, automatizado y actualizado al menos diariamente
- ☐ Sí, parcialmente automatizado y actualizado al menos mensualmente
- ☐ Existe, pero es manual e incompleto
- ☐ No existe inventario fiable

2.2. ¿En qué medida se utilizan identificadores estándar (CPE, SBOM, etiquetas cloud, etc.) para relacionar activos con vulnerabilidades? [web:19][web:22]

- ☐ Uso sistemático de identificadores estándar

- ☐ Uso parcial en los activos más críticos
- ☐ Uso experimental / piloto
- ☐ No se utilizan identificadores estándar

2.3. ¿En el inventario se identifica qué activos soportan servicios esenciales o procesos críticos de negocio? [web:33]

- ☐ Sí, de forma exhaustiva
- ☐ Sí, pero solo para algunos servicios / procesos clave
- ☐ Se hace de forma informal o incompleta
- ☐ No se distingue entre activos críticos y no críticos

2.4. ¿Se consideran dependencias de terceros y cadena de suministro en la evaluación de la criticidad de activos? [web:33][web:39]

- ☐ Sí, con criterios documentados
- ☐ Parcialmente, en algunos contratos o proveedores clave
- ☐ Solo como reacción ante incidentes
- ☐ No se consideran de forma sistemática

3. Proceso de detección y evaluación inicial

3.1. ¿Con qué frecuencia se ejecutan escaneos de vulnerabilidades sobre los activos clave? [web:33][web:35]

- ☐ Continuamente o casi en tiempo real
- ☐ Semanalmente
- ☐ Mensualmente
- ☐ Trimestralmente
- ☐ Menos frecuente / No hay periodicidad definida

3.2. ¿Se integran fuentes externas de inteligencia de vulnerabilidades (CISA KEV, Vulnrichment, CERTs, vendors) en el proceso de detección y priorización? [web:19][web:22][web:25]

- ☐ Sí, múltiples fuentes externas integradas automáticamente
- ☐ Sí, pero con integración manual o parcial
- ☐ Solo se consultan fuentes externas puntualmente
- ☐ No se utilizan fuentes externas

3.3. ¿Se recolectan datos sobre explotación real (incidentes detectados, intentos de explotación, telemetría SOC) para alimentar la priorización? [web:20][web:25]

- ☐ Sí, con correlación sistemática con CVE
- ☐ Sí, pero solo en grandes incidentes
- ☐ De forma puntual / ad hoc
- ☐ No se incorporan datos de explotación real

3.4. ¿La organización utiliza EPSS u otros modelos de probabilidad de explotación para complementar CVSS? [web:20][web:23]

- ☐ Sí, EPSS integrado en las herramientas de vulnerabilidades
- ☐ Sí, se consulta EPSS u otros modelos manualmente
- ☐ No, pero se está considerando
- ☐ No, ni se plantea

4. Adopción y entendimiento de SSVc

4.1. ¿Cuál es el nivel de conocimiento de SSVc dentro de la organización? [web:24][web:19][web:37]

- ☐ Elevado: el marco SSVc se usa en procedimientos formales
- ☐ Medio: se conoce y se ha experimentado con él
- ☐ Bajo: se ha oído mencionar, pero no se aplica
- ☐ Nulo: nunca se ha tratado el tema

4.2. ¿La organización ha definido algún modelo propio de SSVc (árbol de decisiones ajustado a su contexto)? [web:24][web:30][web:19]

- ☐ Sí, modelo formal documentado y versionado
- ☐ Sí, modelo en fase piloto o “beta”
- ☐ No, pero se utiliza el modelo genérico de CERT/CC o CISA
- ☐ No se utiliza ningún modelo SSVc

4.3. ¿Para qué roles se ha construido (o se prevé construir) un modelo SSVc específico? [web:24][web:30][web:37]

- ☐ Operador de activos/servicios (explotación)
- ☐ Equipo de desarrollo / DevSecOps
- ☐ Coordinador interno (CISO / Oficina de Riesgos)
- ☐ Gestión de proveedores y cadena de suministro
- ☐ No se han diferenciado roles

4.4. ¿Qué decisiones se pretende soportar con SSVc?

- ☐ Priorización de parches / remediación
- ☐ Priorización de controles compensatorios / mitigaciones
- ☐ Priorización de pruebas de seguridad (pentest, red team, etc.)
- ☐ Priorización de notificación a terceros / reporting regulatorio
- ☐ Ninguna en particular, todavía es exploratorio

4.5. ¿Se dispone de herramientas (internas o comerciales) que soporten SSVc y permitan automatizar parte de las decisiones? [web:8][web:21][web:18]

- ☐ Sí, herramientas con soporte explícito de SSVc (árbol, campos, reporting)
- ☐ Sí, pero con adaptaciones manuales o scripts propios
- ☐ No, pero está en estudio o licitación
- ☐ No, y no se contempla a corto plazo

5. Puntos de decisión SSVC y datos disponibles

En esta sección nos interesa la aplicación práctica de puntos de decisión típicos de SSVC: explotación, automatización, impacto técnico, impacto en la misión y exposición. [web:24][web:30][web:19]

5.1. ¿Cómo se determina el estado de explotación de una vulnerabilidad? [web:22][web:25][web:20]

- ☐ Se combinan fuentes externas (KEV, CERTs, vendors) y datos propios (incidentes, telemetría)
- ☐ Se utilizan solo listas externas como KEV
- ☐ Se basa principalmente en juicio experto interno
- ☐ No se evalúa explícitamente el estado de explotación

5.2. ¿Se distingue entre PoC pública, explotación limitada y explotación masiva/automatizada? [web:24][web:25]

- ☐ Sí, con criterios documentados y registrados
- ☐ Sí, pero de manera informal
- ☐ No, se usa solo “explotada/no explotada”
- ☐ No se considera la explotación

5.3. ¿Cómo se evalúa la automatización potencial de los ataques (Automatable)? [web:8][web:24]

- ☐ Basado en presencia de exploits en marcos comunes (Metasploit, etc.) y campañas observadas
- ☐ Basado en juicio de analistas SOC/Threat Intel
- ☐ No se evalúa la automatización de manera sistemática
- ☐ No se contempla este atributo

5.4. ¿La organización tiene un criterio formal para el impacto técnico (“Technical Impact”) en confidencialidad, integridad y disponibilidad? [web:24][web:19]

- ☐ Sí, formalmente definido y aplicado de forma homogénea
- ☐ Sí, pero varía según el equipo o el proyecto
- ☐ No, se improvisa según cada caso
- ☐ No se evalúa de manera estructurada

5.5. ¿Cómo se evalúa el impacto en la misión / servicio esencial / seguridad pública? [web:24][web:33]

- ☐ Con un modelo formal (categorías de servicio, impacto en continuidad, indicadores regulados)
- ☐ Con un modelo parcial (solo para servicios “top”)
- ☐ A criterio del responsable en cada caso
- ☐ No se evalúa de forma explícita

5.6. ¿Se tiene en cuenta la exposición (internet-facing, segmentación, controles compensatorios) como punto de decisión? [web:24][web:33]

- ☐ Sí, con datos de arquitectura y gestión de configuración
- ☐ Sí, pero basado en percepción general de exposición
- ☐ Solo en entornos muy concretos (por ejemplo, OT)
- ☐ No, solo se mira la criticidad CVSS

6. De árbol de decisión a acción concreta

6.1. ¿La organización utiliza categorías SSVC (por ejemplo Act / Attend / Track) o equivalentes propios para guiar la acción? [web:24][web:5][web:26]

- ☐ Sí, se usan explícitamente las categorías SSVC u otras equivalentes formalizadas
- ☐ Sí, pero solo en documentación interna sin reflejo operativo
- ☐ No, se utiliza únicamente “criticidad” numérica (CVSS u otras)
- ☐ No se dispone de categorización consistente

6.2. Cuando se etiqueta una vulnerabilidad como máxima prioridad (Act o equivalente), ¿existe un plazo formal para su remediación? [web:6][web:33][web:32]

- ☐ Sí, con plazos definidos (p. ej., 72 h) y seguimiento automático
- ☐ Sí, pero con seguimiento manual y no siempre aplicado
- ☐ Hay orientaciones, pero sin plazos vinculantes
- ☐ No existen plazos definidos

6.3. ¿Cómo se gestiona el backlog de vulnerabilidades de alta prioridad? [web:27][web:32]

- ☐ Con revisión periódica, criterios claros de descarte/aceptación de riesgo y reporting a dirección
- ☐ Con revisiones ocasionales cuando el backlog es inasumible
- ☐ Básicamente se va “apagando fuegos”
- ☐ No se tiene visibilidad agregada del backlog

6.4. ¿Se documentan las decisiones de aceptar, transferir o mitigar el riesgo frente a vulnerabilidades de alta prioridad? [web:33][web:39]

- ☐ Sí, sistemáticamente y con trazabilidad
- ☐ Sí, pero solo para casos significativos
- ☐ De forma informal (correos, tickets sueltos)
- ☐ No se documentan

6.5. ¿Se comunican externamente (a clientes, reguladores, CERT) las decisiones de gestión de vulnerabilidades críticas cuando procede? [web:33][web:39]

- ☐ Sí, según procedimientos definidos
- ☐ Sí, pero solo en situaciones excepcionales
- ☐ Rara vez
- ☐ Nunca

7. Métricas e indicadores (IGM, eficacia, ROI)

7.1. ¿La organización calcula métricas de tiempo medio de detección (MTTD) de vulnerabilidades? [web:32][web:35]

- ☐ Sí, de forma sistemática
- ☐ Sí, pero solo para algunos ámbitos
- ☐ No, aunque disponemos de datos para calcularlo
- ☐ No, ni se calcula ni se plantea

7.2. ¿Se calcula el tiempo medio de remediación (MTTR) por criticidad o categoría de acción (Act/Attend/Track)? [web:32][web:27]

- ☐ Sí, cruzando criticidad/acción y MTTR
- ☐ Sí, pero solo por criticidad CVSS
- ☐ No, aunque podría calcularse
- ☐ No se calcula

7.3. ¿Se monitoriza el porcentaje de vulnerabilidades críticas remediadas dentro del plazo objetivo? [web:32][web:27][web:33]

- ☐ Sí, y se reporta periódicamente a la dirección
- ☐ Sí, pero solo en informes internos técnicos
- ☐ No, aunque sería deseable
- ☐ No se monitoriza

7.4. ¿Se mide la correlación entre las decisiones de priorización (SSVC, CVSS+EPSS, etc.) y los incidentes reales? [web:16][web:20][web:25]

- ☐ Sí, mediante análisis regular de incidentes
- ☐ Sí, de forma puntual tras incidentes graves
- ☐ No, pero se está considerando
- ☐ No se mide

7.5. ¿Se calcula algún indicador global de madurez (IGM) de la gestión de vulnerabilidades, agregando aspectos de proceso, tecnología y resultados?

- ☐ Sí, con un modelo propio
- ☐ Sí, con un modelo de referencia (NIST, ISO, etc.) adaptado
- ☐ No, pero se dispone de elementos dispersos
- ☐ No se calcula ningún indicador global

7.6. ¿Se evalúa el retorno de la inversión (ROI) en gestión de vulnerabilidades (por ejemplo, reducción de incidentes, evitar multas, mejora reputacional, eficiencia operativa)? [web:27][web:32][web:41]

- ☐ Sí, con estimaciones cuantitativas
- ☐ Sí, pero mayormente cualitativo
- ☐ No, se considera un “coste de hacer negocios”
- ☐ No se evalúa en absoluto

8. NIS2, cumplimiento y reporting

8.1. ¿La organización está explícitamente sujeta a NIS2 o normas nacionales derivadas? [web:33][web:36][web:39]

- ☐ Sí, como entidad esencial
- ☐ Sí, como entidad importante
- ☐ No, pero seguimos buenas prácticas alineadas
- ☐ No aplica

8.2. ¿Se han adaptado los procesos de gestión de vulnerabilidades para cumplir los requisitos de NIS2 (continuidad, documentación, reporting, supervisión)? [web:33][web:39]

- ☐ Sí, con procesos documentados y evidencias
- ☐ Parcialmente, en fase de implantación
- ☐ Está planificado, pero aún no iniciado
- ☐ No se ha abordado

8.3. ¿Se dispone de una matriz SLA de respuesta a vulnerabilidades vinculada a criticidad/acción (por ejemplo, “críticas = 72h”)? [web:33][web:32]

- ☐ Sí, y se aplica y monitoriza
- ☐ Sí, pero la monitorización es limitada
- ☐ Hay orientaciones, pero no SLA formales
- ☐ No existe matriz SLA

8.4. ¿Se generan informes periódicos con evidencia de la gestión del ciclo completo (detección, priorización, remediación, validación) listos para auditorías o requerimientos regulatorios? [web:33][web:32][web:39]

- ☐ Sí, de forma sistemática
- ☐ Sí, pero solo a petición
- ☐ No, aunque disponemos de los datos dispersos
- ☐ No se generan

9. Automatización, herramientas y capacidades técnicas

9.1. ¿Hasta qué punto está automatizado el pipeline de gestión de vulnerabilidades (desde el descubrimiento hasta el ticket de remediación)? [web:8][web:18][web:27]

- ☐ Altamente automatizado, con integración entre escáner, inteligencia de amenazas, SSVC/EPSS y ticketing
- ☐ Parcialmente automatizado, con algunos eslabones manuales
- ☐ Mayoritariamente manual
- ☐ Manual casi en su totalidad

9.2. ¿Se utilizan APIs o formatos estándar (JSON SSVC, CSAF, etc.) para intercambiar datos de priorización con terceros o herramientas internas? [web:19][web:28][web:30]

- ☐ Sí, integración basada en estándares
- ☐ Sí, pero principalmente mediante exportaciones ad hoc
- ☐ No, cada herramienta vive en su propio universo
- ☐ No se ha planteado

9.3. ¿La organización explora o usa ya capacidades avanzadas (machine learning, scoring dinámico, análisis de peor caso) para priorizar vulnerabilidades? [web:17][web:20][web:16]

- ☐ Sí, en producción
- ☐ Sí, en fase piloto

- ☐ No, pero se está estudiando
- ☐ No, ni está en el radar

10. Cultura, personas y futuro cercano

10.1. ¿Qué porcentaje aproximado del tiempo del equipo de seguridad se dedica a la gestión de vulnerabilidades frente a otras tareas?

- ☐ < 10 %
- ☐ 10-25 %
- ☐ 25-50 %
- ☐ > 50 %

10.2. ¿Se percibe la gestión de vulnerabilidades como una carga inevitable o como una palanca de mejora real de la resiliencia?

- ☐ Principalmente como palanca estratégica
- ☐ Mezcla: algo de palanca, mucho de carga
- ☐ Principalmente como carga inevitable
- ☐ No hay percepción clara

10.3. ¿Qué grado de apoyo percibe de negocio / líneas operativas para aplicar medidas derivadas de decisiones SSVC o equivalentes?

- ☐ Alto apoyo, incluso en medidas disruptivas
- ☐ Apoyo moderado, con negociaciones frecuentes
- ☐ Resistencia habitual, salvo obligación regulatoria o incidente
- ☐ Apoyo muy limitado

10.4. ¿Cuál es la prioridad estratégica de mejorar la priorización de vulnerabilidades (incluida adopción de SSVC) en los próximos 24 meses?

- ☐ Máxima prioridad
- ☐ Importante pero competirá con otras iniciativas
- ☐ Moderada
- ☐ Baja

10.5. Si tuviera que elegir una sola mejora en este ámbito para el próximo año, ¿cuál sería? (respuesta abierta)

- ____

Fin de la encuesta. Gracias por demostrar, al menos, que alguien lee este tipo de cosas con atención.